ADios

Breaking up with Active Directory

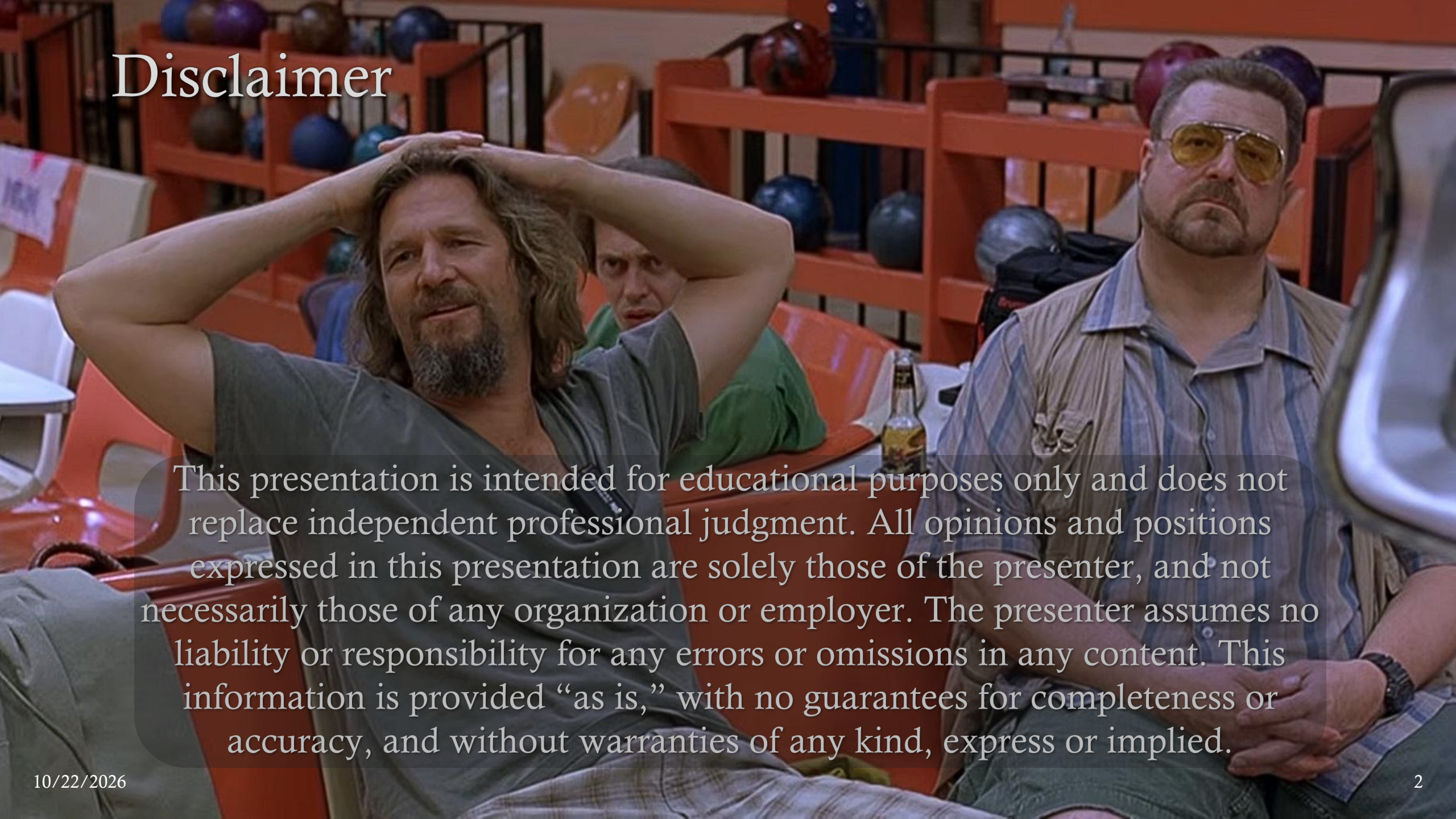
Daniel Jarboe

Empowering teams to achieve goals
with well-secured technology.

https://www.linkedin.com/in/**daniel-jarboe**/

The Neon Temple: Volition (@morethannature)

Disclaimer



This presentation is intended for educational purposes only and does not replace independent professional judgment. All opinions and positions expressed in this presentation are solely those of the presenter, and not necessarily those of any organization or employer. The presenter assumes no liability or responsibility for any errors or omissions in any content. This information is provided “as is,” with no guarantees for completeness or accuracy, and without warranties of any kind, express or implied.

TL;DR

- Active Directory (AD) was great for the year 2000.
- AD is here to stay, and **hybrid identity** models will persist for years, but **cloud-native identity** is the strategic direction of travel for many organizations.
- Moving to cloud-native identity won't be for everyone, and it's not turnkey or "just a migration" … but it is getting easier.

Putting a label on our “situationship”

On-prem AD: Domain controllers managing local domain-joined devices and users

Hybrid: AD + Entra ID with sync; one foot in each world, but with your shoelaces tied together

Cloud-native: Entra-only joined; no Domain Controllers nor managed Domain Services

Terminology Check: In this context, you can be “on-prem” in a private or public cloud

Relationship ground rules

1. **It's Complicated.** We are speed-dating this topic.
2. This "Breaking up with Active Directory" session ***is not*** **about FOSS alternatives** or non-Microsoft platforms to manage corporate identities and technology assets.
3. **This is an awareness talk**, not a how-to guide.
   - Already running Hybrid AD?
   - Currently cloud-native but considering an "upgrade" to Hybrid AD?

Maybe minimizing AD is worth another look.

My “baggage” / prior history

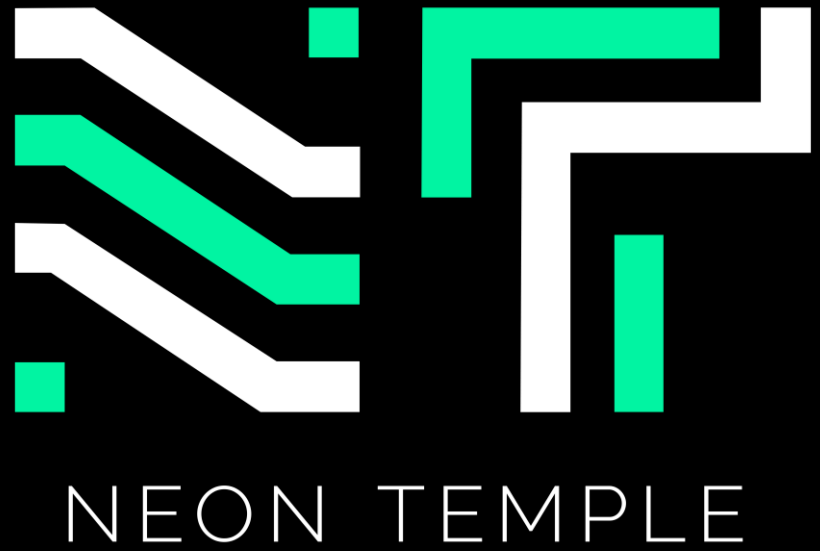
- Early career exposure (& internships) to a variety of multi-platform non-Microsoft proprietary closed systems and Open Systems in enterprise environments
- Spent the first 5 years after my degree in a (*very* odd) combo Mainframe Systems Programmer and Linux Systems Administrator role (at then AOL Time Warner)
  - Supporting z/OS in a mainframe parallel sysplex cluster environment, performed a z/OS upgrade
  - Writing CICS and DB2 zSeries assembler user exits to improve admin / add business-required functionality
  - Linux virtual machine orchestration (s390/s390x on the z/VM hypervisor)
    - SuSE Linux Enterprise Server, Red Hat Linux 7.1 and Red Hat Enterprise Linux 2.1, and Debian 3.0 (Woody)
    - Big Endian byte storage, Complex Instruction Set with different lengths and behaviors based on addressing mode
    - s390 used 32-bit general-purpose and control registers supporting 24-bit and 31-bit addressing modes
    - s390x z/Architecture (z for “Zero Downtime”) used 64-bit general-purpose registers and supported 64-bit addressing

My “baggage” / prior history

- Back then, when you were re-platforming Windows Servers to Linux in a corporate environment, on non-commodity architectures (s390/s390x), you were working with open-source communities
  - Projects like Samba, Squid caching proxy, CUPS – you’d occasionally trip over bugs, and fix them
  - CVE 2003-0084 (RHSA-2003:114) RCE in the mod_auth_any module for Apache HTTP Server
    - Failure to escape shell metacharacters in authentication username → commands executed by the webserver
- Switched to leadership team: Distributed Systems server & desktop teams first, expanding into the Shared Global Services team, Move To Cloud projects, Engineering, and IT Controls initiatives
  - Converted Windows PCs in the customer support center to diskless Linux Thinstation clients
  - Supported business teams during migrations to O365 (in its relatively early days)
  - Hands-on many “side projects” – e.g. training a ML model for Service Desk ticket triage and assignment
- Landed in Financial Services (P&C Insurance, ~400 employees): IT Controls, +Security, +CISO. Later +Infra/Cloud, +Service Desk and Endpoints, +Prod Support, +Business Intelligence.

Today’s journey

1. Before we have ‘The Talk’
2. Remembering the good times
3. A wayward glance
4. It’s not you, it’s me
5. Breaking up is hard to do
6. The glow-up
7. Closure



Remembering the good times

AD; what it solved and why we stay

A moment of appreciation

- Active Directory Domain Services first shipped with **Windows 2000 Server.**
- AD solved real problems in an era of late-90s enterprise environment assumptions.
- AD brought better scalability, centralized administration, hierarchical OUs, Group Policy, stronger authentication (Kerberos), LDAP-based directory, DNS integration, delegation of administration.
- AD remains a critical IT system for most organizations.

Active Directory is entrenched

- Eliminating AD is operational infeasible for many orgs.
- Over the years, orgs have built and accumulated layers of configuration and integration upon their Active Directory foundations.
- Many enterprise tools assume AD exists. *More than you might think.*
- Migration away from AD is non-trivial.

The cloud is not for everyone

- Air-gapped/disconnected environments
- Sovereignty and compliance
- Legacy server-heavy environments
- Mission-critical control and resiliency
- Operational autonomy (minimize vendor dependency and trust)

There are cloud-only vulnerabilities

- Vulnerabilities are often on-prem only
  - or privately disclosed and patched in cloud tenants before on-prem patches are published
- But cloud-specific vulnerabilities *are a thing*
  - Cloud-only features and functionality add cloud-only attack surface
- **Dirk-jan Mollema** – 2025 “One token to rule them all”
  - Undocumented “token features” + vulnerability = **full cross-tenant access**
  - Responsibly disclosed and fixed before exploitation. But it happened, and it’s *wild*.

A wayward glance

The case for leaving

To eliminate the accumulated configuration debt

- AD features evolved, so do security best practices, and business & IT processes. Would you build new like it is today?
- Misconfigurations and legacy configurations accelerate compromise.
  - NTLM configuration & authentication fallbacks
  - SMB & file services mixed policies or not requiring signing
  - Legacy Kerberos configurations
  - Active Directory Certificate Services (ADCS/PKI)
  - Privilege delegation & DACL sprawl
  - GPO attack surface
  - Tier-0 assets and trust boundaries

AD was not built for zero trust

- AD was designed for
  - High interoperability
  - Frictionless enterprise collaboration
- realized through
  - Transitive trust
  - Broad credential usability
  - Shared identity context
- All this leads to well-worn playbooks for threat actors.

AD was not built for zero trust

```
Is NTLM present?
├── Yes; Can I steal a credential hash?
│        ├── Yes → Pass-the-Hash (PtH)
│        └── No; Can I relay NTLM authentication?
│                 ├── Yes → NTLM Relay
│                 └── No → Fall back to Kerberos attack paths
└── No; Kerberos-based attacks
        └── Do I already control KRBTGT credentials (DA or DC compromise)?
            ├── Yes → Golden Ticket
            └── No; Do I control a service account key (Kerberoast, etc.)?
                    ├── Yes → Silver Ticket
                    └── No; Can I steal live Kerberos tickets?
                            ├── Yes → Pass-the-Ticket / token abuse
                            └── No → Look for delegation / AD CS abuse
```

- All this leads to well-worn playbooks for threat actors.

Active Directory is RaaS approved! 👍

DM us to **sell your IA on %** locking with all major lockers depending on target; must be ready to run **AD commands** or **Okta commands**, or show `/etc/openldap/ldap.conf /var/log` and `ip -a addr && ssh -i /home/$$/.ssh/*pem $$@(ip addr ip's)` or anything else you find relevant to showing us

Rules:
- no companies under 500M revenue
- no RF/PRC/DPRK/Belarus companies
- no health

IA rates:
25% for any AD joined system.
10% for Okta, Azure portal, AWS IAM root, etc

were also recruiting employees/insider at the following!!!!

- Any company providing Telecommunications (Claro, Telefoinica, ATT, and other similar)
- Large software/gaming corporations (Microsoft, Apple, EA, IBM, other similar)
- Callcenter/BPM (Atento, Teleperformance, and other similar)
- Server hosts (OVH, Lcaweb, and other similar)

If you are not sure if you are needed then send a DM and we will respond!!!!
If you are not a employee here but have access such as VPN or VDI then we are still interested!!

You will be paid if you would like. Contact us to discuss that

TO NOTE: WE ARE NOT LOOKING FOR DATA, WE HAVE IT ALL ALREADY, WE ARE LOOKING FOR THE EMPLOYEE TO PROVIDE US A VPN OR CITRIX TO THE NETWORK, or some anydesk

note: we are mainly focused on US AU UK CA FR

for inquires: @SLSHsupport

❤️ 7 💩 3 😀 2

1.3K SLSHsupport edited 1:38 AM

Active Directory is RaaS approved! 👍

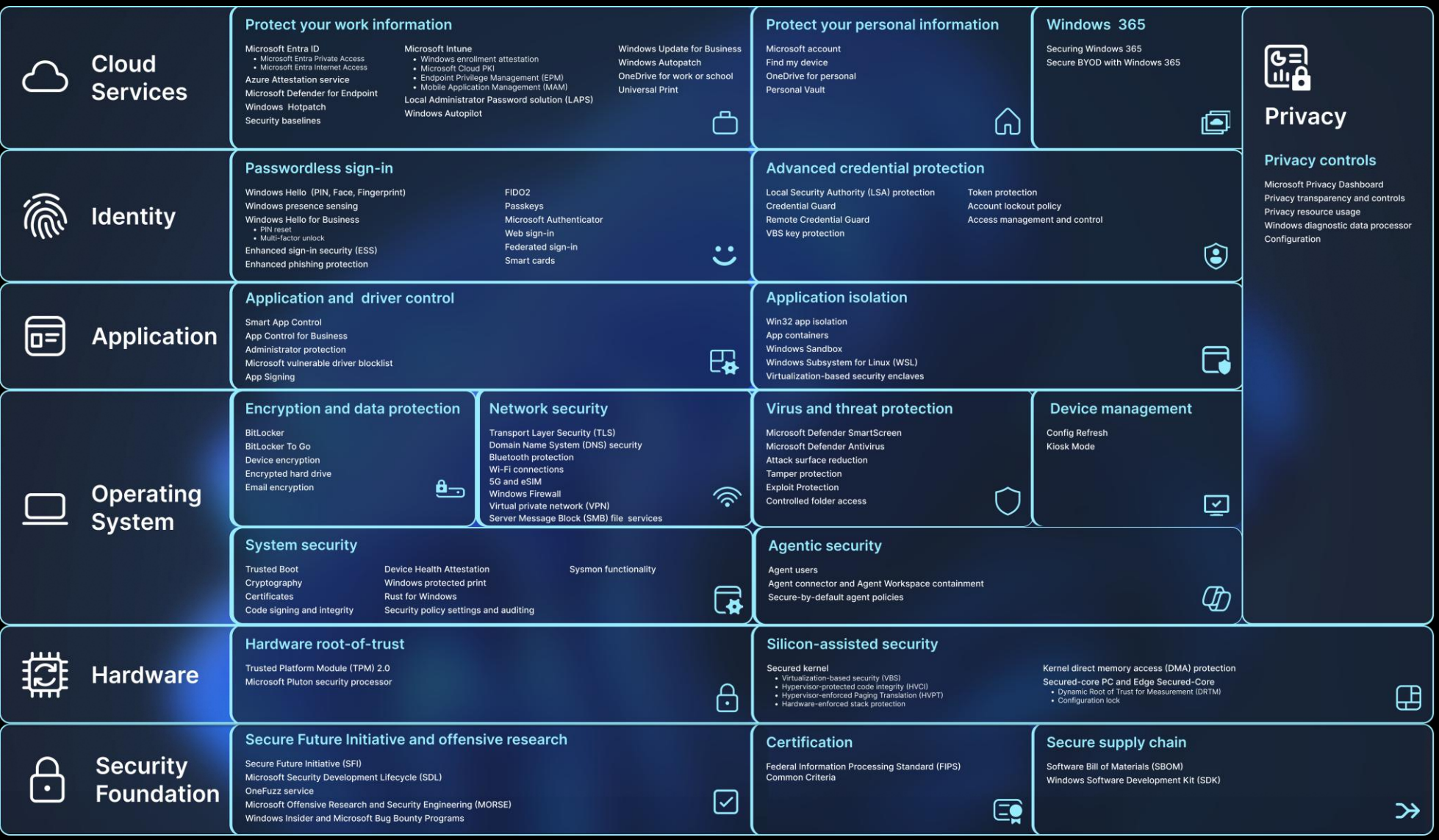
DM us to **sell your IA on %** locking with all major lockers depending on target, must be ready to run **AD commands** or **Okta commands**, or show `/etc/openldap/ldap.conf /var/log` and `ip -a addr && ssh -i /home/$$/.ssh/*.pem $$@(ip addr ip's)` or anything else you find relevant to showing us

Rules:
- no companies under 500M revenue
- no RF/PRC/DPRK/Belarus companies
- no health

IA rates:
25% for any AD joined system.
10% for Okta, Azure portal, AWS IAM root, etc

were also recruiting employees/insider at the following!!!!

Security architectures and trust



AD reflects an **era** when hardware roots of trust couldn't be assumed, and the chain of trust mindset from endpoint to cloud was less mature.

Toto, I’ve a feeling we’re not in Kansas anymore

- 90s era enterprise assumptions are often obsolete in today’s environments.
  - Hyper-connectivity?
  - Cloud services?
  - Remote work?
- Most orgs have already shifted to the cloud, and hybrid-identity models.

Entra ID blast radius reduction by design

- **Authentication** policy enforced centrally with one logical token issuer in a tenant
  - vs. a per-domain authority with distributed policy and identity trust bounded by the forest
- **Authorization** uses cryptographically protected tokens with explicit scopes/roles
  - vs. identity-based and implicitly inherited across the trust boundary
- **Enforcement** is independently validated per resource (with a few exceptions)
  - vs. dependent on shared trust and accepted identity context

Better visibility* (with an important caveat)

- **MS Graph Logs and M365 control and data plane visibility**
  - Everything is an API
  - The main “Unified” logs are immutable and relatively normalized across workloads
  - Unified Audit Log records semantic actions (e.g., file viewed vs. download vs. shared)
  - The 2024 Midnight Blizzard attack led directly to expanded customer visibility, with improved API-level observability, additional identity telemetry, legacy blind spots brought into scope, and more Entra ID logs available for free and enabled by default.

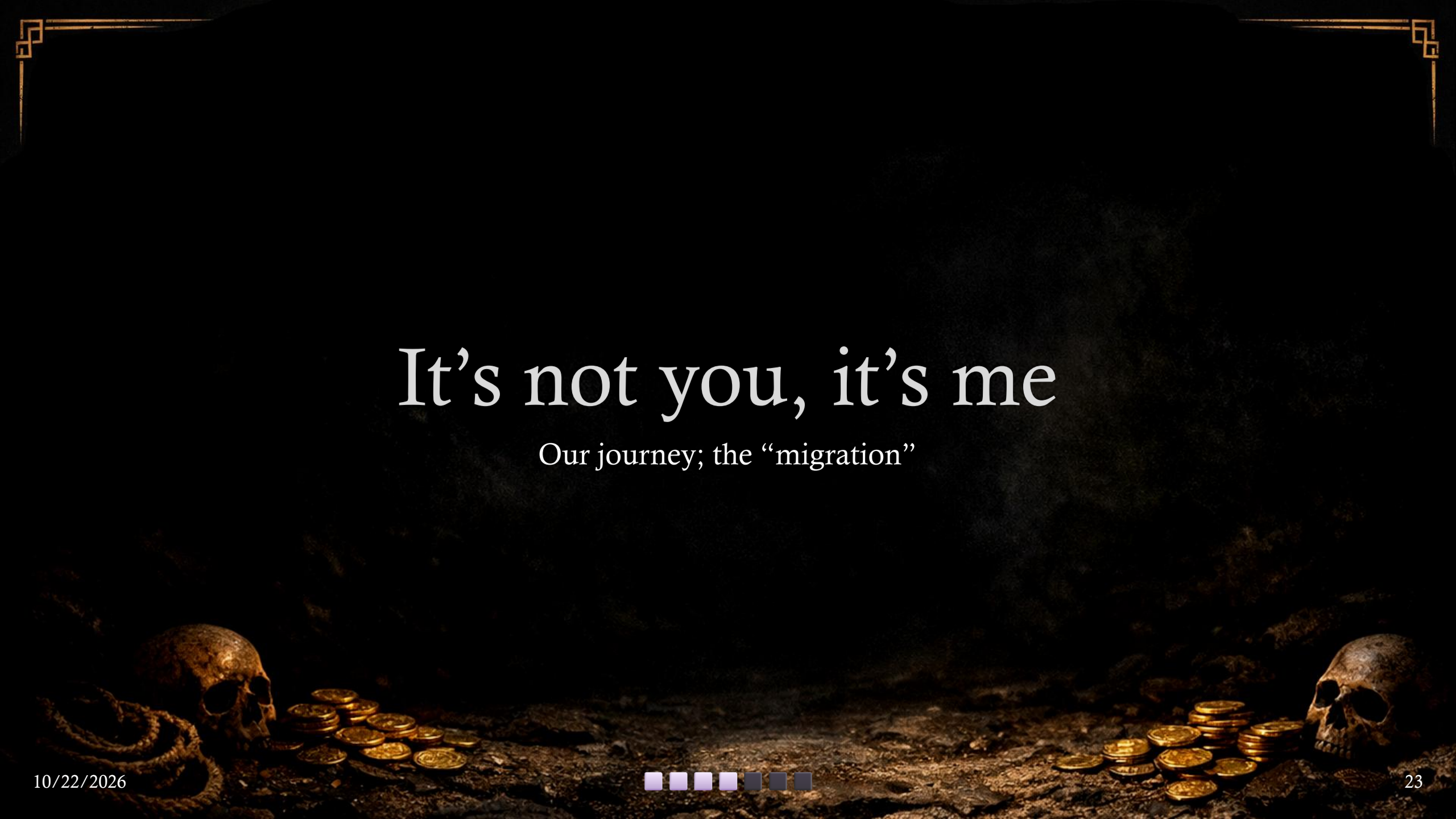
*__Big caveat__: visibility at the layers *you* manage in the Shared Responsibility Model. The Service Provider layers are hidden, which may be slightly terrifying, or untenable.

Entra ID is where the action is

- **Active investment** – IAM research & development dollars are going into Entra. AD investment is more limited, mostly where enhancements improve Hybrid interoperability/security.
- **Auth & identity** – Native platform integration for workload- and agent-native identity security, passwordless and phishing-resistant MFA (FIDO2, passkeys), etc.
- **Device management** (Intune P1) – Intune config/policies/apps, device compliance, autopilot provisioning (no DC line-of-sight requirement), company portal apps
- I ❤️ **Conditional Access** (Entra ID P1) – Granular authentication decisions
  - Separately from CA, Enterprise App "require user assignment" is another nice toggle.

It’s not you, it’s me

Our journey; the “migration”



The jump-off point

- Publicly traded holding company with multiple insurance-related companies in different states (including NY), undergoing a **major business transformation.**
- **Many systems and apps no longer needed**, systems and operational employees moved to new buyers or were directly placed with other carriers.
- Monolithic ~20-year-old directory that had been shared by all companies, and primarily designed to serve the IT processes and requirements of a former carrier.

“Hybrid AD” without intentionality

- Hybrid AD felt like a bolt-on
  - Device policy via GPOs; all laptops imaged in lab by IT with line-of-site to DCs
  - Little use of M365 Groups / Teams, low use of SharePoint Online
  - Shared drives mapped from shares on traditional Windows file servers
  - Folder redirection for per-user locations like “My Documents”
  - Different third-party solutions for SSO/Federation, MFA, Mobile Device Management
  - Nearly all identity synced from DCs to the Cloud – privileged accounts synced too 👎

All things considered

- Our directory was well-configured
  - Audited SOX & SEC & NY DFS cyber regulation helped set compliance baselines
  - Hardened insecure defaults and attack paths revealed by security penetration test reports and/or dual-use security auditing tools like Bloodhound
  - Directory access control entries were aligned to least privilege and explainable
  - Surviving credentialed internal penetration tests without loss of domain control
- Modest network segmentation (room for improvement), but GREAT outbound firewall policy with granular (to specific users/functions) AppID allow rules.

The question: how do we make this work?

- Considering…
  - the degree of current infrastructure misalignment to the go-forward business strategy
  - users already facing and powering through significant changes
  - our small go-forward team size

  … a greenfield buildout *was* on the table
- **We chose the nuclear option:**
  - Clean break, new user objects and devices, new Entra-only tenant
  - KISS – it is *a* way, but certainly not the only way
  - Started rolling out new devices and accounts

An experiment?

- Eliminating infra servers and staying native Entra ID was a *target*…
  - … but we still had business operations to run, so… priorities.
- Not a one-way door decision:
  - **Plan A**: Start with cloud-native identity.
  - **Plans B (and C):** Add AD capabilities with Entra Domain Services (or full AD Domain Services) if needed for legacy dependencies, but *with a purposeful* cloud-first approach to hybrid identity.
- When **Plan A** hit an obstacle, the first answer was always: *"let's see if we can find another way to make this work without resorting to Domain Services."*

Breaking up is hard to do

Wasn’t quite ready for that

Ditching the file servers was a *very* big deal!

- Azure Files required hybrid/on-prem, so O365? New paradigms take adjustment.
- Business data owners were asked to help copy their own files to O365.
  - Business teams understood the "go-forward" business strategy
  - Received *clear* direction from executives/legal for what to keep, and what not to keep (e.g., limits on data retention for files no longer needed for business operations)
  - New **data lifecycle policies** were well-defined and coordinated
  - IT worked with departments to guide M365 Teams and Teams Channels structure/planning
  - Data owners drove File Explorer copies from old file shares to endpoint OneDrive Sync folders
    - Benefits: ↑ data-owner scrutiny for what to keep, ↑ adoption of "ownerless" files
  - IT ran post-process validation to confirm 1:1 source to destination matches. Data owners reviewed IT's report and confirmed or corrected exceptions.

File server migration to O365 callouts 1/2

- SPO enforces shorter total path lengths (400 chars)! Revealed quirky habits:
  - Sentences-long folder names to describe the files within
  - Deep nesting of *repetitively* named subfolders at every level, e.g., instead of…
    - **Quarterly Memos****TPS Reports****2026****Q1**\
    - Some would recursively repeat the full hierarchy, like: **Quarterly Memos****Quarterly Memos TPS Reports****Quarterly Memos TPS Reports 2026****Quarterly Memos TPS Reports 2026 Q1**\
- Beyond that, File Explorer copies to OneDrive synced locations worked great!
  - Created/last-modified file date attributes were preserved (for files)
  - Interrupted File Explorer copies *could* result in missing files but *never* half-written files. If a file was present, it was whole. Whenever we *did* find a corrupted file in the new location, it was traceable back to a corrupted source file on the original server.

File server migration to O365 callouts 2/2

- Large document libraries are a bit unwieldy.
- The People vs. Purview: Employees were emotionally invested in old files.
  - Files inherited purview labels as they landed in SPO sites and folders.
  - Even when files are irrelevant, many people hated to throw them away on purpose.
  - Even more people hate the idea of policies to enforce files getting deleted *for them* (i.e., limits on data retention).
  - Giving data-owners the ability to label their own records *can* be dangerous.
  - Generally, business users spending time on data hygiene/governance is a tough sell.

File server behaviors that don’t translate

- Locking/sync semantics are fundamentally different from SMB
  - Pros/cons with multi-user file workflows
- O365 “loves” to update Office document package metadata on file open
  - File restore testing from O365 backups can create identical document content bodies with different file hashes. Requires consideration for file restore testing audits 😣
  - Excel’s autosave behavior is very different for files stored on SPO/ODfB vs. file shares
    - O365 files: edit commits immediately. Network share files: edits are tracked client-side with auto-recover checkpoints, but no write-back to the original location without user action
    - Some users asked for kludgy things like disabling Excel-autosave (targeted via Intune policy).
    - Versioning helps, but “restoring” a prior version in practice means creating a brand-new version: earlier file content, but newer last modified date 👎

Entra ID admin is a *different job* than AD admin

Entra ID admin is a *different job* than AD admin

- AD work skews toward operational reliability and infrastructure engineering of a stateful directory.
  - Defenders infer intent from signals with limited semantic context, and detect credential-based attack techniques or the abuse of implicit trust chains inside the network.
- Entra ID work skews toward holistic policy-driven access and identity governance across a *managed* identity control plane.
  - Defenders focus on preventing unintended policy bypasses (any holes that line up in your swiss cheese), getting to least privilege, and limiting token or consent misuse.

These are different skills. Some teams may have both skillsets already. We were "AD people" who learned Entra and Intune things along the way; trial by fire.

Entra ID admin is a *different job* than AD admin

Conceptual & implementation differences 1/2

- Direct vs. group member vs. nested (transitive) group membership *can* matter
  - Some authorization scenarios require *direct* membership.
  - Transitive group membership doesn't always confer the privilege of direct membership.
- Microsoft 365 Groups vs. Security Groups
  - M365 groups are resource containers (shared mailbox and calendar, SharePoint team site, etc.)
  - Teams are built on M365 groups and can include channels (each with its *own* site and document libraries, with channel messages stored in mailbox folders).
  - 'Group.Read.All' is a *data plane* permission for M365 groups that includes Team conversations, not least-privilege if you only need directory enumeration of security groups and membership like 'GroupMember.Read.All'.

Conceptual & implementation differences 2/2

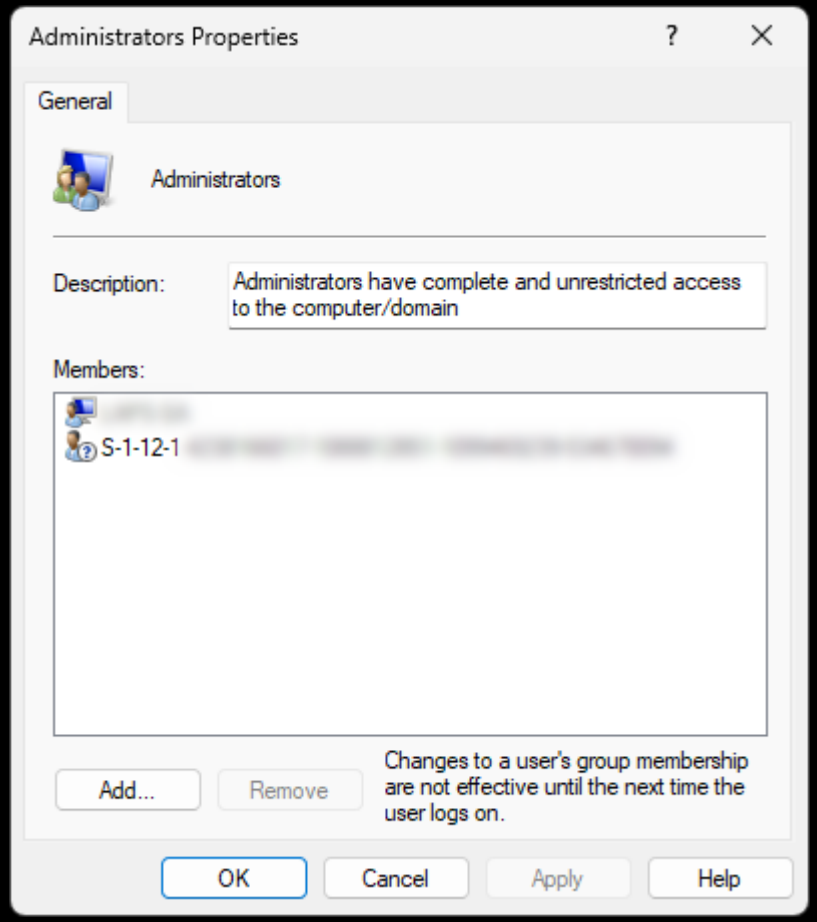
- Delegated Permissions vs. Application Permissions
  - **Delegated authorization via OAuth grants** – application acts on user behalf, within delegated scopes, possibly including `offline_access` (obtain access token without the user signed-in).
  - **Application-only access via assigned app roles** – application service principal acts on resources for itself (e.g., automation scenarios). Consider application RBAC to narrow scope.
- And more…
  - App Registrations (possibly multi-tenant) & their related per-tenant Enterprise App service principals
  - Access Tokens, Refresh Tokens (vs. Kerberos service tickets and TGTs)
  - Flat directory with Graph relationships and policy evaluation (vs. hierarchical directory scoped policies)
  - Azure PIM eligible roles vs. permanent assignment (vs. time-to-live PAM in AD)
  - Administrative Units for scoping (different from AD Organizational Units)

Sometimes frustrating 1/2

- **Password policy limitations** – Native Entra-ID one-size-fits-all password policy
  Be ready to update your organization's documented password policy requirements!
  - In Entra ID, your password policy is 8-character-minimum with required complexity; customization is limited to optional password expiration and a custom banned word list.
  - And no fine-grained password policies like AD. Microsoft's nudge is to go passwordless.
- **Server management without domain services** – feels incomplete without GPOs.
  - GPO-equivalent management planes lack full feature parity.
- **PowerShell ecosystem fragmentation** – assembly collisions for different services
  Microsoft Graph (Mg-) modules do not always play nice with Azure (Az-) modules.
  - Neither plays well with PnP.PowerShell or ExchangeOnlineManagement

Sometimes frustrating 2/2

- **Entra ID as an IdP** – some limitations
  - multi-valued claims/assertions?
  - refresh token rotation on use?
- **Entra ID SID translation** – limited on endpoints
  - Local Administrators group contains an unknown SID… User? Security Group? Role? Deleted?
  - SID-to-name resolution: built around local SAM and AD security authorities, not Entra ID
  - "Manually" convert SID to ObjectId and find the match.



Take the time (reduce exposure, assume breach)

- **Intentionality tax:** The cloud demands greater intentionality to manage access and exposure. There is a cognitive burden, but planning improves outcomes.
  - Public vs. Private in Azure: you *must* be deliberate about what's internet facing, segmentation
  - Does the service metering basis (billing dimensions) reward right-sizing, turning off after-hours?
  - Role least privilege, and Entra/Azure Privileged Identity Management (PIM)
  - Conditional Access Policies: ↑ functionality + ↑ signals = ↑ complexity
  - Admin consent and least-privilege MS Graph permissions
  - When assigning application permissions to service principals, scoping access to workload-specific authorizations (Application RBAC) for some M365 apps, e.g.,
    - Mail.Read and Mail.Send with Exchange Online application role assignments to narrow scope
    - Sharepoint Sites.Selected permission for targeted access to specific site collections
    - OneDrive Files.SelectedOperations.Selected instead of File.Read.All and Files.ReadWrite.All

The glow-up

Surprise, surprise!

Relentless improvements

- The pace of innovation and enhancements to Entra ID really is remarkable

Feature	When	Notes
Windows LAPS (cloud)	2023	Local admin password rotation via Entra/Intune for cloud-only devices.
Cloud PKI	2024	Not *full* AD CS replacement yet (we used SCEPman + RADIUSaaS bundle).
Azure Files Kerberos Auth support for cloud-only identities	**Preview 2025, GA 2026**	**Azure Files can now accept Kerberos tickets issued by Entra ID (preview for cloud-only users, used to *require* hybrid-join, constraints still exist). Not so useful if you're off SMB/CIFS Windows File Sharing.**
Global Secure Access	**2025**	**ZTNA, capabilities like limiting refresh token use to compliant networks**
Source of Authority 👈	**2026**	**Switch authoritative write path for identity objects from AD to Entra ID.**
Many Intune improvements	…	No one thing, but steady-stream of Intune improvements and features, for more comprehensive endpoint device-management capabilities.
Conditional Access features, PR-MFA auth methods like Passkeys	…	No one thing, but steady-stream of Conditional Access improvements and features, like session-based controls, agent resources, user actions, attribute-based resource selections, Continuous Access Evaluation, token binding

Things we liked more than I expected 1/2

- The team learn a lot building fresh with new technologies, and it was ours!
  - It's more exciting to build new than maintain old stuff built by someone else
  - Learned both while creating, and also in winding down the old
- Very active and generous tech community – Blue, red, fresh and vibrant
  - A plethora of security researchers and identity experts sharing insights, building impressive projects and open-source tools, celebrating and explaining shiny new features in preview, etc.
- Access control model & convenient features (dynamic groups, system-managed-identities)
- Microsoft Graph is *slick* – a uniform, multi-product API, very powerful for automation

Things we liked more than I expected 2/2

- Vendor consolidation – fewer interfaces, data siloes, and integration headaches
  - And we did still choose several non-MS solutions to improve tenant-independency (data recovery, separate administrator control plane, diversification & peace of mind)
- Getting off file servers *ultimately* improved user experiences in many ways
  - **Performance:** high read/write of local files with sync vs. network shares; ↑ reliability, ↑ speed
  - **Structure:** File reorg + OneDrive shortcuts + sharing options kept related files together, reduced over-sharing, reduced duplication, and simplified data ownership
  - **Improved safety of external collaboration**: more options for policy granularity, and principle of least privilege to reduce blast-radius of a compromised vendor account
  - **Oversight:** If you're in the cloud leveraging M365 things, you're getting more value out of the integrated ecosystem (M365 Copilot, Purview, Graph, Intune, Entra, etc.)

Closure

And they all lived happily ever after

Validation

An underwriter during a cyber discussion for D&O insurance policy renewal:

"favorable view" of the consolidation to a single IAM platform…

Excerpt from a security penetration testing report (starting as authenticated user):

"Eliminating on-premises Active Directory has meaningfully reduced the available attack surface and has rendered many traditional internal attack vectors ineffective."

Ben Rollin, Founder/Lead Cybersecurity Consultant for Vilkas Cybersecurity, and Principal Training Developer for Hack The Box (HTB Academy)

We remain native Entra ID today

- A big win: IT improved its position (shift left) as a consulted stakeholder in the vendor on-boarding/procurement process
  - IT security review gate early in contracts review
  - Increased communication and coordination with business departments during the vendor selection process, *prior* to application/service selection and implementation
- This resulted in decisions that improved
  - service reliability
  - total cost of ownership
  - identity and access management integration *with Entra ID*

Support Resources (tip of the iceberg)

- entra.news – Merill is a top resource creator and curator for Entra ID community
- aka.ms/ad2entra – Resources for an AD Minimization journey
- maester.dev – an open-source security posture assessment framework for M365

TL;DR

- Active Directory (AD) was great for the year 2000.
- AD is here to stay, and **hybrid identity** models will persist for years, but **cloud-native identity** is the strategic direction of travel for many organizations.
- Moving to cloud-native identity won't be for everyone, and it's not turnkey or "just a migration" … but it is getting easier.

Is it time to reconsider whether your organization can say, ADios?

Thank you / Q&A

ADios; Breaking up with Active Directory

Daniel Jarboe

Empowering teams to achieve goals
with well-secured technology.

https://www.linkedin.com/in/**daniel-jarboe**/

The Neon Temple: Volition (@morethannature)